

EPICODE — Institute of Technology

Windows Event Logs

Configurazione e Gestione dei Log di Sicurezza

Analisi Event ID critici nel registro Sicurezza, verifica policy di audit tramite secpol.msc e auditpol, configurazione logging Login/Logoff e validazione della generazione degli eventi

Studente	Mauro Picca
Data	4 Giugno 2026
Corso	EPICODE — Cybersecurity & Ethical Hacking
Modulo	S9 L4 — Windows Event Logs: Configurazione e Analisi
Ambiente	Metasploitable / Windows 10 pro (VirtualBox)

Attività svolta esclusivamente a fini didattici in ambiente di laboratorio controllato

Cybersecurity & Ethical Hacking | EPICODE

Indice

1. Sintesi	3
2. Introduzione ai Windows Event Logs	3
3. Analisi del Registro di Sicurezza	4
4. Verifica delle Policy di Audit	6
5. Verifica della Configurazione Effettiva	8
6. Configurazione del Logging Login/Logoff	9
7. Generazione e Validazione degli Eventi	11
8. Conclusioni	12

1. Sintesi

L'attività di laboratorio ha avuto come obiettivo l'analisi e la configurazione dei log di sicurezza di Windows attraverso il Visualizzatore Eventi e gli strumenti di auditing integrati nel sistema operativo. Sono stati esaminati gli eventi relativi ai processi di autenticazione, verificata la configurazione delle policy di audit tramite secpol.msc e auditpol, e configurata la registrazione degli eventi di Login e Logoff. La configurazione è stata validata generando nuovi eventi e verificandone la corretta registrazione nel registro Sicurezza.

2. Introduzione ai Windows Event Logs

I log di sicurezza di Windows rappresentano uno degli strumenti principali a disposizione degli amministratori di sistema e degli analisti di sicurezza per monitorare le attività svolte su un sistema operativo. Attraverso la registrazione degli eventi è possibile individuare accessi autorizzati, tentativi di accesso non riusciti, utilizzo di privilegi amministrativi e altre attività rilevanti ai fini della sicurezza.

Windows integra un sistema di auditing nativo che, una volta configurato, consente di registrare tali eventi nel registro Sicurezza del Visualizzatore Eventi. Questo registro è una delle fonti primarie di evidenza durante un'attività di Incident Response o di monitoraggio continuo in ambiente SOC.

Registro Windows	Contenuto	Uso tipico in sicurezza
Sicurezza (Security)	Autenticazioni, accessi, policy, privilegi — richiede auditing attivo	Incident Response, monitoraggio accessi, SIEM
Sistema (System)	Errori hardware, driver, servizi di sistema	Troubleshooting, stabilità sistema
Applicazione (App)	Log delle singole applicazioni installate	Debug applicativo, errori software
Inoltro eventi	Aggregazione eventi da macchine remote	Centralizzazione log in ambienti enterprise

 Il registro Sicurezza di Windows è vuoto o parziale finché le policy di audit non sono attivate. Molte installazioni Windows di default hanno l'auditing disabilitato o minimo — è una delle prime cose da verificare e configurare in un hardening di sistema.

3. Analisi del Registro di Sicurezza

La prima fase dell'attività ha previsto l'apertura del Visualizzatore Eventi tramite il comando:

```
eventvwr
```

Successivamente è stato selezionato il registro Registri di Windows → Sicurezza. L'analisi degli eventi presenti ha evidenziato la presenza di diversi Event ID associati ai processi di autenticazione.

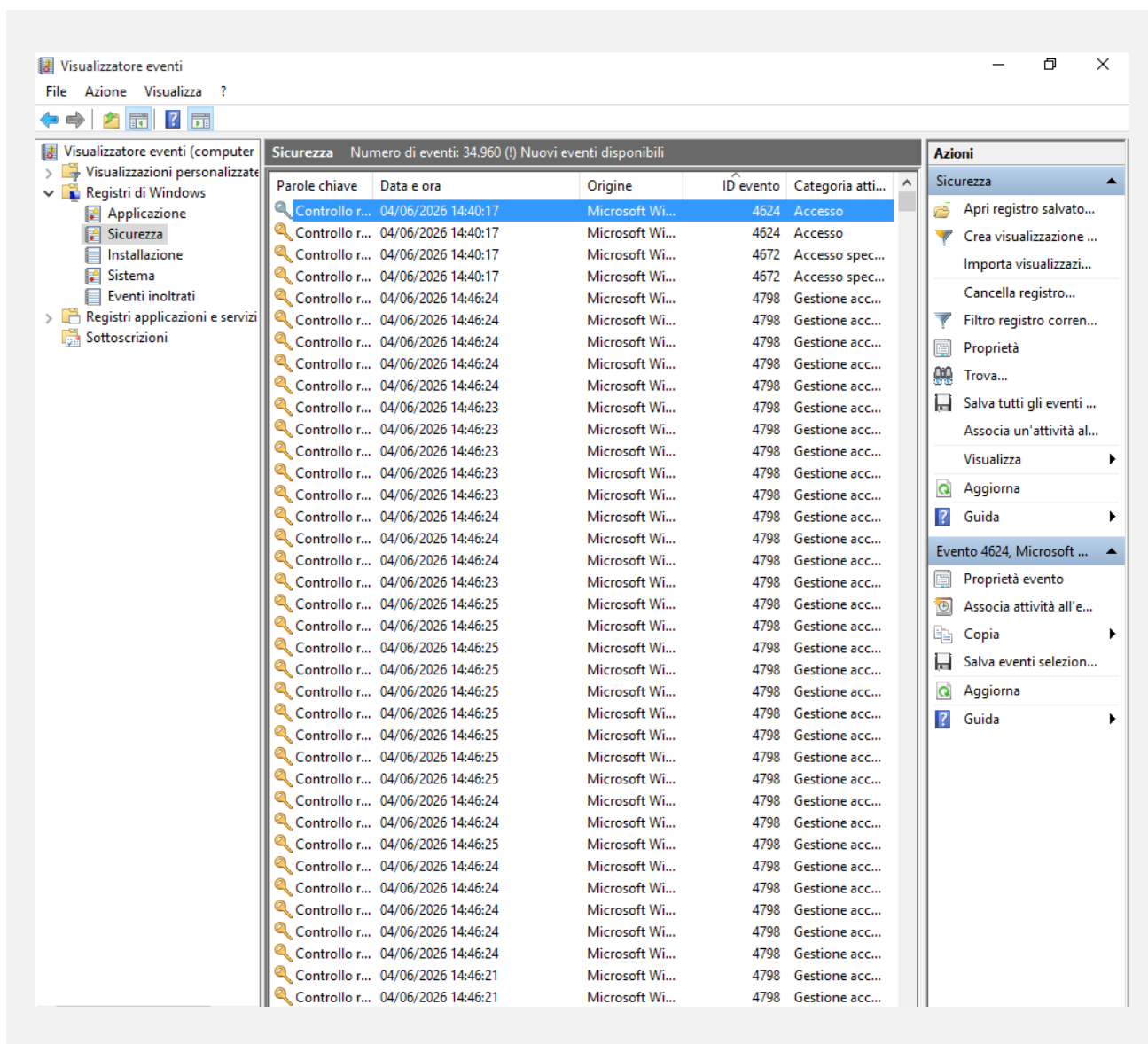


Figura 1 – Visualizzatore Eventi: registro Sicurezza con gli eventi di autenticazione presenti.

Tra gli eventi osservati, i più significativi dal punto di vista della sicurezza sono:

Event ID	Nome Evento	Descrizione	Rilevanza SOC
4624	Logon	Accesso riuscito al sistema — registra tipo di logon, utente, IP sorgente e metodo di autenticazione	● Standard — baseline normale di ogni sistema
4648	Explicit Credential Use	Utilizzo esplicito di credenziali diverse da quelle della sessione corrente (es. RunAs)	● Attenzione — può indicare lateral movement o privilege abuse
4672	Special Privileges	Assegnazione di privilegi speciali a una nuova sessione — tipicamente account amministrativi	● Alto — monitorare per rilevare escalation di privilegi
4798	User Group Membership	Enumerazione dei gruppi locali di un utente — spesso parte di ricognizione post-accesso	● Attenzione — possibile attività di discovery dopo compromissione

L'analisi dettagliata di un evento 4624 ha confermato la registrazione di un accesso riuscito, con tutte le informazioni diagnostiche: timestamp, utente, dominio, tipo di logon (interattivo, rete, servizio) e indirizzo IP sorgente.

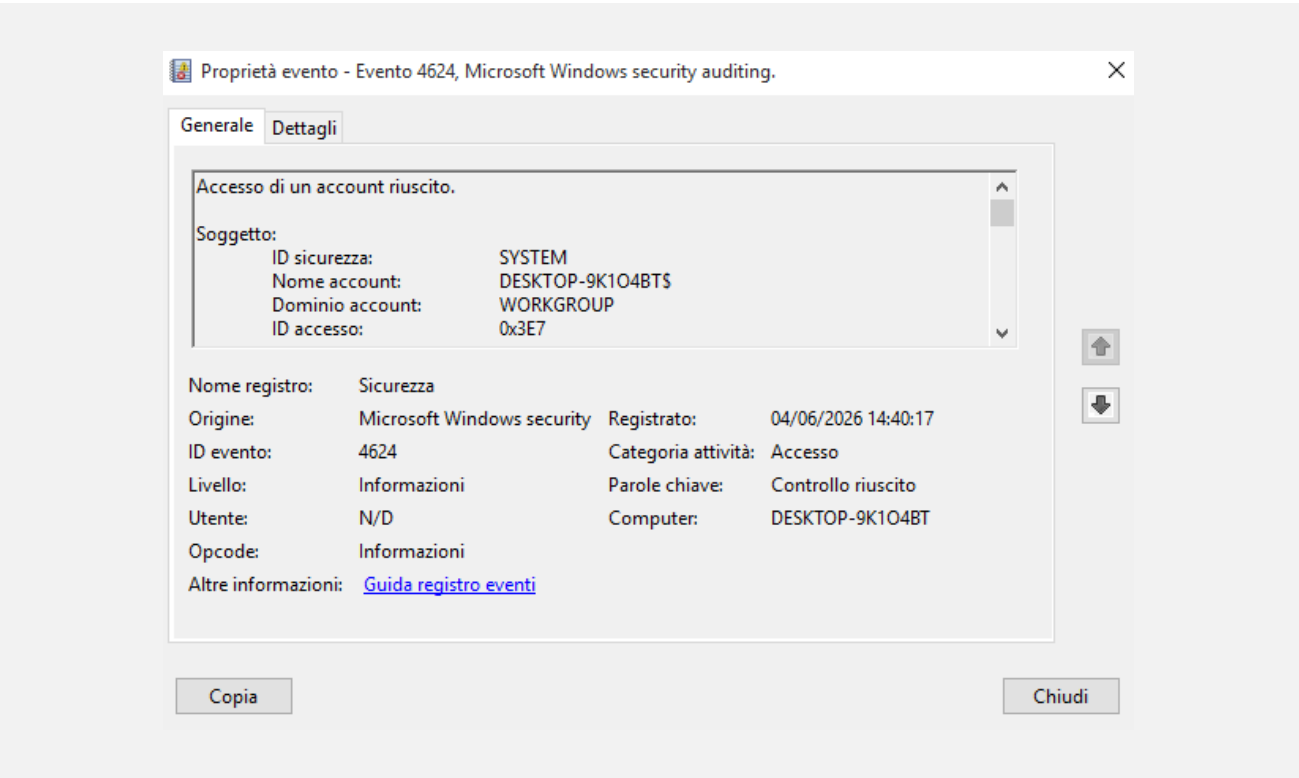


Figura 2 – Dettaglio dell'evento 4624: accesso riuscito con timestamp, utente e tipo di logon.

🔍 L'Event ID 4624 è uno degli eventi più monitorati in ambito SOC: un picco anomalo di 4624 da IP inusuali o in orari non lavorativi può indicare un attacco di password spraying o brute force andato a buon fine. Il tipo di logon (campo Logon Type) è particolarmente informativo: Logon Type 3 = accesso di rete, Type 10 = Remote Interactive (RDP).

4. Verifica delle Policy di Audit

4.1 Policy Classiche tramite secpol.msc

Per comprendere la configurazione dell'auditing è stata aperta la console delle policy di sicurezza locali:

```
secpol.msc
```

Nel percorso Criteri locali → Criteri di controllo, le policy risultavano tutte impostate su "Nessun controllo" — indicando che l'auditing di base non era configurato.

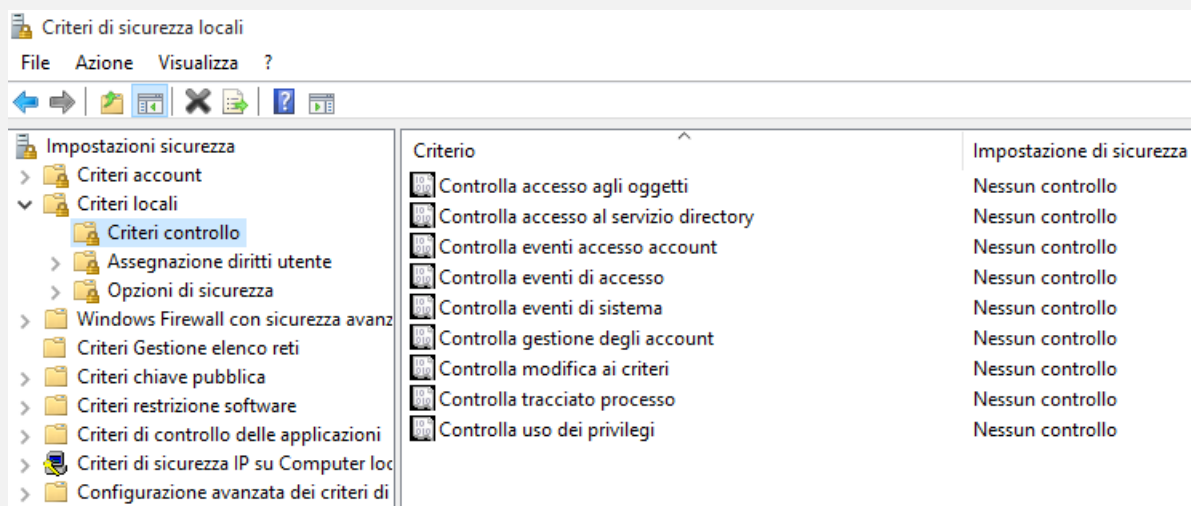


Figura 3 – secpol.msc: Criteri di controllo impostati su "Nessun controllo" — auditing base non configurato.

4.2 Policy Avanzate

Sono state analizzate le policy avanzate nel percorso Configurazione avanzata dei criteri di controllo → Accesso/Fine sessione. Anche le sottocategorie avanzate risultavano non configurate.

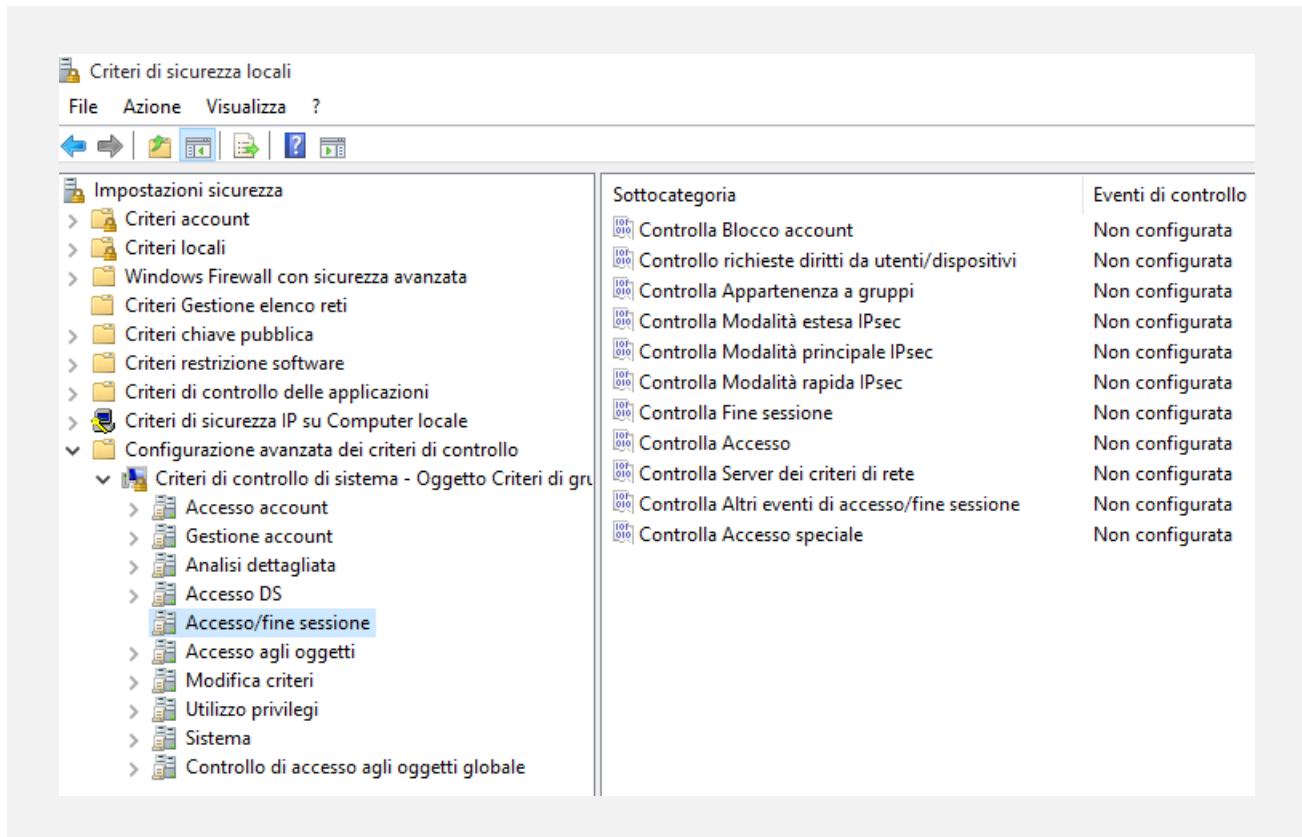


Figura 4 – Audit avanzato: sottocategorie Accesso/Fine sessione non configurate.

Questa situazione ha evidenziato una discrepanza: il registro Sicurezza conteneva già eventi (come visto nella sezione 3), ma le policy visualizzate in secpol.msc non mostravano alcuna configurazione attiva. Questo ha reso necessario verificare la configurazione effettiva tramite uno strumento specifico.

💡 secpol.msc mostra le policy definite tramite Group Policy Objects (GPO). Se una GPO di dominio sovrascrive le impostazioni locali, secpol.msc non la mostra correttamente. Il comando auditpol è l'unico strumento affidabile per conoscere la configurazione di auditing realmente attiva.

5. Verifica della Configurazione Effettiva

La configurazione reale dell'auditing è stata verificata tramite il comando:

```
auditpol /get /category:*
```

L'output di auditpol mostra la configurazione effettiva di tutte le categorie e sottocategorie di auditing, indipendentemente da come vengono visualizzate in secpol.msc. Le colonne indicano se vengono registrati gli eventi riusciti (Success) e/o quelli falliti (Failure) per ciascuna categoria.

Il risultato ha mostrato che il sistema registrava già eventi relativi agli accessi e alle disconnessioni in alcune sottocategorie — spiegando la presenza di eventi nel registro Sicurezza nonostante secpol.msc mostrasse "Nessun controllo".

```
C:\Windows\system32>auditpol /get /category:*
Criteri di controllo di sistema
Categoria/Sottocategoria      Impostazione
Sistema
  Estensione stato sicurezza    Nessun controllo
  Integrità sistema             Esito positivo e negativo
  Driver IPsec                  Nessun controllo
  Altri eventi di sistema       Esito positivo e negativo
  Modifica stato sicurezza      Operazione riuscita
Accesso/fine sess.
  Accesso                       Operazione riuscita
  Disconnessione                Operazione riuscita
  Blocco account                Operazione riuscita
  Modalità principale IPsec     Nessun controllo
  Modalità rapida IPsec         Nessun controllo
  Modalità estesa IPsec         Nessun controllo
  Accesso speciale              Operazione riuscita
  Altri eventi di accesso/fine sessione Nessun controllo
  Server dei criteri di rete    Esito positivo e negativo
  Richiesti diritti da utenti/dispositivi Nessun controllo
  Appartenenza a gruppi         Nessun controllo
Accesso agli oggetti
  File system                   Nessun controllo
  Registro di sistema           Nessun controllo
  Oggetto kernel                Nessun controllo
  SAM                           Nessun controllo
  Servizi di certificazione     Nessun controllo
  Generato dall'applicazione     Nessun controllo
  Manipolazione handle          Nessun controllo
  Condivisione file             Nessun controllo
  Mancata elaborazione pacchetti Piattaforma filtro WindowsNessun controllo
  Connessione a Piattaforma filtro WindowsNessun controllo
  Altri eventi di accesso agli oggetti Nessun controllo
  Condivisione file dettagliata Nessun controllo
  Archivi rimovibili            Nessun controllo
  Gestione temporanea criteri centrali Nessun controllo
Uso del privilegio
  Utilizzo privilegi non sensibili Nessun controllo
  Altri eventi di utilizzo di privilegi Nessun controllo
  Utilizzo privilegi sensibili   Nessun controllo
Analisi dettagliata
  Creazione di processi          Nessun controllo
  Chiusura di processi           Nessun controllo
  Attività DPAPI                 Nessun controllo
  Eventi RPC                     Nessun controllo
  Eventi Plug and Play           Nessun controllo
Modifica criterio
  Modifica criteri di autenticazione Operazione riuscita
  Modifica criteri di autorizzazione Nessun controllo
  Modifica criteri a livello di regola MPSSVCNessun controllo
  Modifica criteri Piattaforma filtro WindowsNessun controllo
  Altri eventi di modifica criteri Nessun controllo
  Modifica del criterio di controllo Operazione riuscita
Gestione account
  Gestione account utente        Operazione riuscita
  Gestione account computer      Nessun controllo
  Gestione gruppi di sicurezza   Operazione riuscita
  Gestione gruppi di distribuzione Nessun controllo
  Gestione gruppi di applicazioni Nessun controllo
  Altri eventi di gestione account Nessun controllo
Accesso DS
  Modifiche servizio directory   Nessun controllo
  Replica servizio directory     Nessun controllo
  Replica dettagliata servizio directory Nessun controllo
  Accesso al servizio directory  Nessun controllo
Accesso account
  Operazioni ticket di servizio Kerberos Nessun controllo
  Altri eventi di accesso account Nessun controllo
  Servizio di autenticazione Kerberos Nessun controllo
  Convalida delle credenziali     Nessun controllo
```

Figura 5 – Output di auditpol /get /category:*. configurazione effettiva dell'auditing su tutte le categorie.

6. Configurazione del Logging Login/Logoff

Per soddisfare i requisiti dell'esercitazione e garantire la registrazione completa degli eventi di autenticazione, è stata configurata esplicitamente la registrazione degli eventi di Login e Logoff tramite auditpol. Sono stati eseguiti i seguenti comandi:

```
auditpol /set /subcategory:"Accesso" /success:enable /failure:enable
auditpol /set /subcategory:"Disconnessione" /success:enable /failure:enable
auditpol /set /subcategory:"Accesso speciale" /success:enable
```

Spiegazione dei parametri:

Parametro	Significato
/set /subcategory:"Accesso"	Configura la sottocategoria Logon — eventi 4624 (successo) e 4625 (fallimento)
/set /subcategory:"Disconnessione"	Configura la sottocategoria Logoff — eventi 4634 e 4647
/set /subcategory:"Accesso speciale"	Configura i logon con privilegi speciali — evento 4672
/success:enable	Abilita la registrazione degli eventi riusciti
/failure:enable	Abilita la registrazione degli eventi falliti (importante per rilevare brute force)

```
C:\Windows\system32>auditpol /set /subcategory:"Accesso" /success:enable /failure:enable
Comando eseguito correttamente.

C:\Windows\system32>auditpol /set /subcategory:"Disconnessione" /success:enable /failure:enable
Comando eseguito correttamente.

C:\Windows\system32>auditpol /set /subcategory:"Accesso speciale" /success:enable
Comando eseguito correttamente.

C:\Windows\system32>
```

Figura 6 – Esecuzione dei comandi auditpol per abilitare il logging di Accesso, Disconnessione e Accesso speciale.

La verifica successiva con auditpol /get /category:* ha confermato l'attivazione della registrazione degli accessi riusciti e falliti per tutte le sottocategorie configurate.

```

C:\Windows\system32>auditpol /get /category:*
Criteri di controllo di sistema
Categorie/Sottocategorie
Sistema
Estensione stato sicurezza
Integrità sistema
Driver IPSec
Altri eventi di sistema
Modifica stato sicurezza
Accesso/fine sess.
Accesso
Disconnessione
Blocco account
Modalità principale IPSec
Modalità rapida IPSec
Modalità estesa IPSec
Accesso speciale
Altri eventi di accesso/fine sessione
Server dei criteri di rete
Richiesti diritti da utenti/dispositivi
Appartenenza a gruppi
Accesso agli oggetti
File system
Registro di sistema
Oggetto kernel
SAM
Servizi di certificazione
Generato dall'applicazione
Manipolazione handle
Condivisione file
Mancata elaborazione pacchetti Piattaforma filtro Windows
Connessione a Piattaforma filtro Windows
Altri eventi di accesso agli oggetti
Condivisione file dettagliata
Archivi rimovibili
Gestione temporanea criteri centrali
Uso del privilegio
Utilizzo privilegi non sensibili
Altri eventi di utilizzo di privilegi
Utilizzo privilegi sensibili
Analisi dettagliata
Creazione di processi
Chiusura di processi
Attività DPAPI
Eventi RPC
Eventi Plug and Play
Modifica criterio
Modifica criteri di autenticazione
Modifica criteri di autorizzazione
Modifica criteri a livello di regola
Modifica criteri Piattaforma filtro Windows
Altri eventi di modifica criteri
Modifica del criterio di controllo
Gestione account
Gestione account utente
Gestione account computer
Gestione gruppi di sicurezza
Gestione gruppi di distribuzione
Gestione gruppi di applicazioni
Altri eventi di gestione account
Accesso DS
Modifiche servizio directory
Replica servizio directory
Replica dettagliata servizio directory
Accesso al servizio directory
Accesso account
Operazioni ticket di servizio Kerberos
Altri eventi di accesso account
Servizio di autenticazione Kerberos
Convalida delle credenziali

```

Figura 7 – Verifica post-configurazione: auditpol conferma Success e Failure abilitati per Logon/Logoff.

⚠ Abilitare il logging dei fallimenti (Failure) per la sottocategoria Accesso è fondamentale per rilevare attacchi brute force e password spraying: ogni tentativo di login fallito genera un Event ID 4625, che un SIEM può correlare per identificare pattern anomali.

7. Generazione e Validazione degli Eventi

Per verificare il corretto funzionamento della configurazione appena applicata è stata bloccata la sessione utente (Win+L) e successivamente effettuato un nuovo accesso al sistema con le credenziali dell'account corrente.

Dopo aver aggiornato il registro Sicurezza nel Visualizzatore Eventi sono stati rilevati nuovi eventi di autenticazione con Event ID 4624, generati immediatamente dopo il re-login.

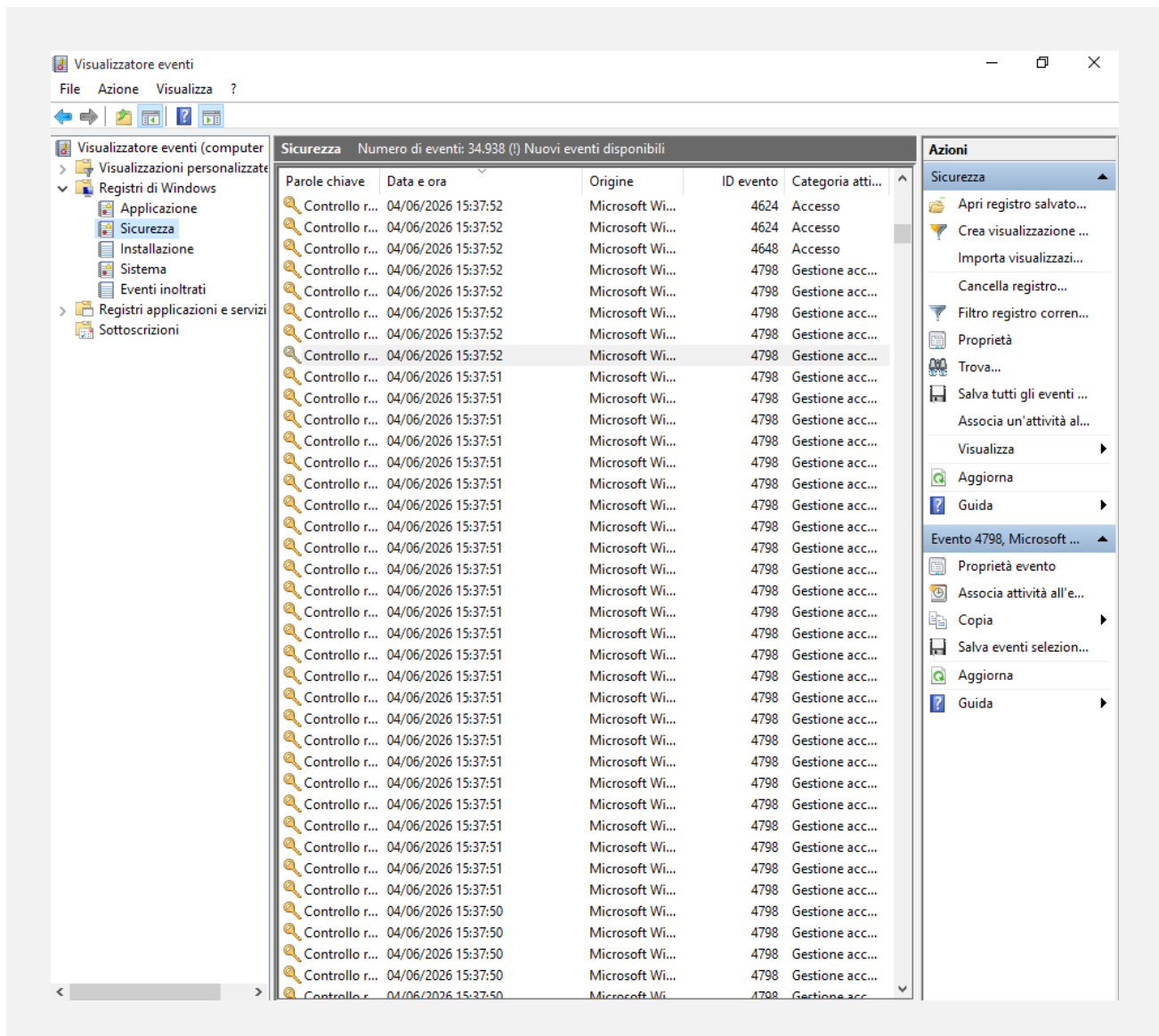


Figura 8 – Nuovi eventi 4624 nel registro Sicurezza generati dopo il blocco e il re-accesso alla sessione.

L'analisi dei dettagli dell'evento ha confermato la corretta registrazione dell'accesso: timestamp preciso, nome utente, tipo di logon (Type 2 = interattivo) e nome della workstation.

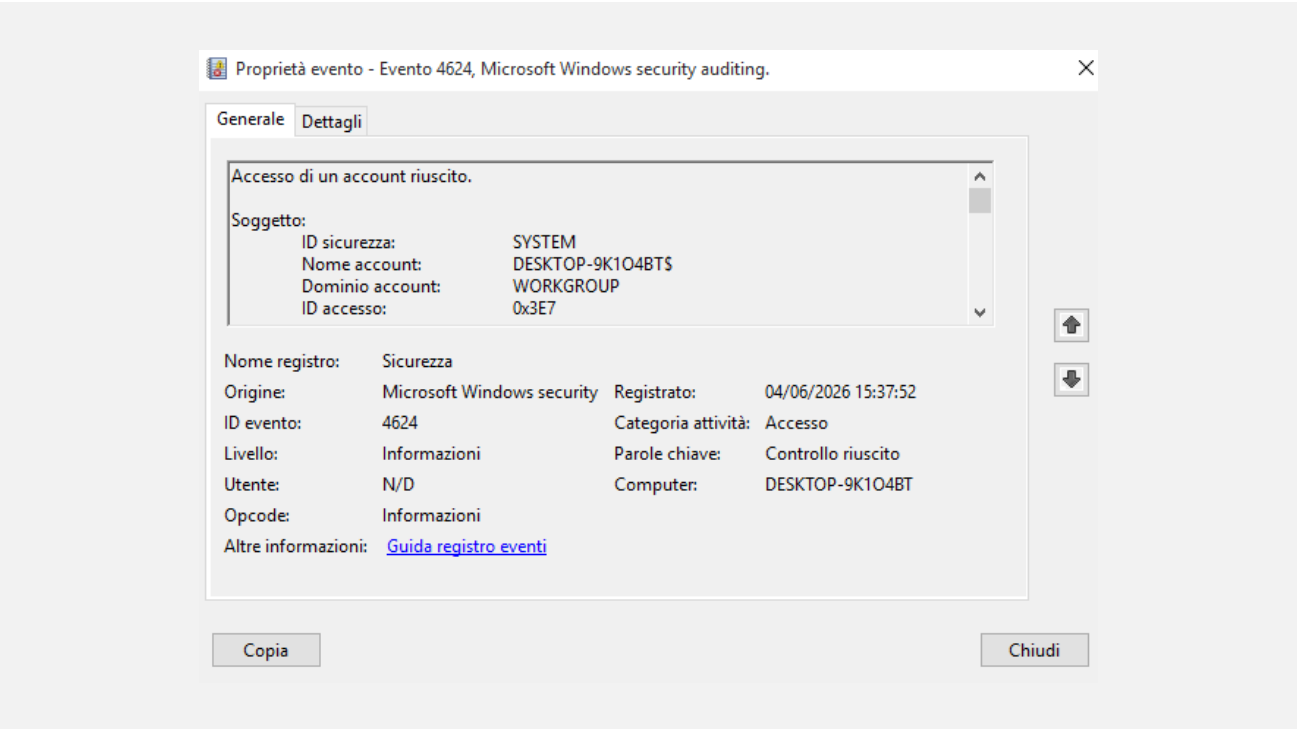


Figura 9 – Dettaglio dell'evento 4624 generato: timestamp, utente, Logon Type 2 (interattivo) confermati.

☒ La configurazione dell'auditing è stata validata con successo: il sistema registra correttamente gli eventi di autenticazione nel registro Sicurezza.

8. Conclusioni

L'attività ha consentito di approfondire il funzionamento del sistema di auditing di Windows e il ruolo dei log di sicurezza nel monitoraggio delle attività di autenticazione. L'utilizzo combinato del Visualizzatore Eventi, di secpol.msc e di auditpol ha messo in luce un aspetto critico: la configurazione visibile in secpol.msc non riflette necessariamente la configurazione effettiva del sistema — solo auditpol fornisce il quadro reale.

Attività	Strumento	Risultato
Apertura registro Sicurezza	eventvwr	☒ Event ID 4624, 4648, 4672, 4798 identificati
Verifica policy audit base	secpol.msc	⚠ Policy su "Nessun controllo" — discrepanza con eventi presenti
Verifica configurazione effettiva	auditpol /get	☒ Auditing parzialmente attivo — stato reale verificato
Configurazione Logon/Logoff	auditpol /set	☒ Success e Failure abilitati per 3 sottocategorie
Validazione logging	eventvwr + login	☒ Nuovi eventi 4624 generati e registrati correttamente

Il laboratorio ha evidenziato l'importanza dei log di sicurezza come strumento di monitoraggio e supporto alle attività Blue Team: un sistema con auditing correttamente configurato è in grado di registrare tentativi di accesso falliti, utilizzo di privilegi amministrativi e attività di ricognizione post-compromissione — fornendo le evidenze necessarie per rilevare e rispondere agli incidenti di sicurezza.

Lesson Learned

- L'auditing Windows è disabilitato per default su molte installazioni: la sola presenza del Visualizzatore Eventi non garantisce la raccolta di log utili. Il primo passo di qualsiasi hardening o assessment è verificare la configurazione effettiva con `auditpol /get /category:*` e abilitare almeno Logon/Logoff, Process Creation e Policy Change.
- L'Event ID 4625 (login fallito) è altrettanto importante del 4624 (login riuscito): senza il logging dei fallimenti, un attacco brute force che non riesce non lascia traccia. La combinazione Success + Failure per la sottocategoria Logon è il minimo indispensabile per un monitoraggio efficace.
- I log locali da soli non bastano: in ambienti enterprise i Windows Event Logs vanno centralizzati in un SIEM (Splunk, Elastic, Microsoft Sentinel) tramite Windows Event Forwarding o agenti. Solo la correlazione di eventi da più macchine permette di rilevare attacchi distribuiti come lateral movement e pass-the-hash.

☒ Tutti gli obiettivi del laboratorio sono stati raggiunti. Il sistema di auditing è stato configurato, verificato e validato con successo.